

WRITEUP LKSN SMK CYBER SECURITY 2023



TEAM NAME : Kepulauan Riau

MEMBER TEAM : - Muhammad Reza Pahlevi
- Raja Alif Alfa At-Thaariq

Challenge Category

1. Reverse Engineering

a. Html2Exe

2. Digital Forensic

b. Silent Sea: Tales of the Feline (1)

3. Welcoming Party

c. Health Checking 

Reverse Engineering

Html2Exe

Description:

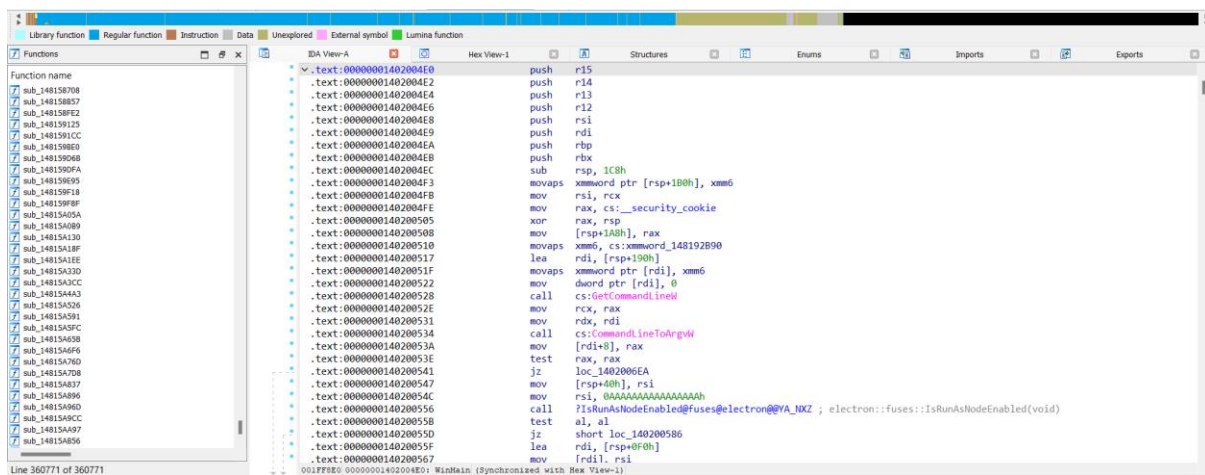
I just bought a cool software that could render my client-side web programming into a single Windows Executable, and I chose a cool Watch! I hope there's no malicious intention behind the seller, ... can you check it out? Perhaps you could find some secrets from it.

Download the [application](#) here

Zip Password: LKS_s3cur3_p4\$\$w0rdzz\$!

Solution:

Diberikan file zip yang ketika saya extract menggunakan password pada deskripsi soal berisikan file clock.exe, json file, package serta library file dan lain-lain. Saat saya decompile file clock.exe tersebut menggunakan IDA Freeware, ada framework electron yang terdapat pada setiap function file exe tersebut.



Selain itu terdapat file app.asar yang cukup mencurigakan karena mengandung strings LKS selain clock.exe file. Saya coba search di google terkait “[Electron Reverse Engineering](#)” dan mengetahui bahwa file app.asar harus diextract menggunakan npx command sehingga memunculkan file website yang terdapat pada file tersebut.

```
(kali@kali)-[~/Downloads/Html2exe]
$ npx asar extract resources/app.asar /home/kali/Downloads/Html2exe/iniaja
Need to install the following packages:
  asar@3.2.0
Ok to proceed? (y) y
npm WARN deprecated asar@3.2.0: Please use @electron/asar moving forward. There is no API change, just a package name change

(kali@kali)-[~/Downloads/Html2exe]
$ cd /home/kali/Downloads/Html2exe/iniaja

(kali@kali)-[~/Downloads/Html2exe/iniaja]
$ ls -la
total 36
drwxr-xr-x 2 kali kali 4096 Oct 25 06:06 .
drwxr-xr-x 5 kali kali 4096 Oct 25 06:05 ..
-rw-r--r-- 1 kali kali 4154 Oct 25 06:06 favicon.ico
-rw-r--r-- 1 kali kali 228 Oct 25 06:06 index.html
-rw-r--r-- 1 kali kali 253 Oct 25 06:06 index.js
-rw-r--r-- 1 kali kali 130 Oct 25 06:06 package.json
-rw-r--r-- 1 kali kali 2231 Oct 25 06:06 script.js
-rw-r--r-- 1 kali kali 130 Oct 25 06:06 style.css
```

Saya cek file tersebut one by one dan terdapat file yang mencurigakan yaitu script.js karena backend website tersebut berasal dari file tersebut. Namun, file script.js ternyata obfuscated. Setelah diobfuscated, terdapat terdapat variable array (hanya angka saja) dan variable lksflag yang akan muncul jika POST ke suatu website atau HTTP Service dalam bentuk JSON API. Saya ubah url website tersebut dari tersebut dari <https://malicious-lksn-surabaya-domain.co.id> ke website yang saya buat menggunakan python command (python3 -m http.server 8080). Lalu saya jalankan file javascript tersebut menggunakan node dengan file solver

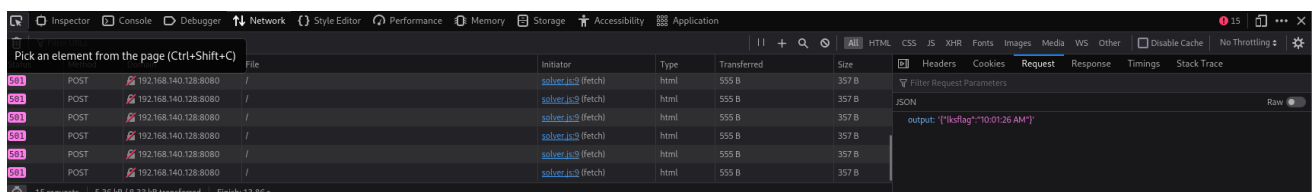
```
function lksflag() {
  time = new Date().toLocaleTimeString();
  return JSON.stringify({ lksflag: time });
}

const flag = { output: lksflag() };

function sendFlag() {
  fetch('http://192.168.140.128:8080', {
    method: 'POST',
    headers: { 'Content-Type': 'application/json' },
    body: JSON.stringify(flag)
  }).then(response => {
    console.log(response);
  });
}

setInterval(sendFlag, 1000);
```

Di browser, ctrl + shift + I lalu ke bagian networks dan pilih yang post lalu ke responses



DIGITAL FORENSIC

Silent Sea: Tales of the Feline (1)

Description:

PT LKSN, Tbk. just hired you as a SOC analyst to perform a network & log monitoring using one of their bleeding-edge SIEM product called Wazuh. In this task, you're assigned to get your hands dirty directly in touch with the internal server logs which is protected and watched by the Wazuh Agents, through the company's Wazuh in OVA format.

Tutorial on Importing the OVA in VMWare Player/Workstation can be viewed [here](#)

Tutorial on Importing the OVA in VirtualBox can be viewed [here](#)

Download the Wazuh OVA file [here](#)

All credentials related to the OVA and Wazuh:

Zip Password (Silent Sea.zip) = LK\$2023_w4zUh_m4dn3zzz_mads!~~

Ubuntu Credentials (Login after boot OVA) = silentsea:silentsea

Wazuh Admin Credentials = admin:6ebY4rgIUXmuCM2lH+8zhGwX7mUcavXp

Notes: Wait for 5-10 minutes after OVA is booted (powered on) and you logged in as silentsea:silentsea credentials, and then visit <https://127.0.0.1> in your main host, or if localhost is not working, get the ip address of the OVA by running command `ip -a` or `ifconfig` to get the ens33 NIC IP Address IPv4

If those steps are properly executed, you should be able to see Wazuh Dashboard Interface in your local machine. If it is still not, please immediately call the judges.

Connect to the nc and answer all of the questions.

nc 13.212.234.124 27543

Notes: Timezone Question in this challenge is GMT+7/UTC+7, as in the Wazuh is still UTC

Author: aseng

Solution:

Diberikan file OVA machine, file text soal dan netcat yang berfungsi sebagai soal dan jika semua soal dijawab benar maka akan muncul flag. Ketika dijalankan OVA tersebut di VMWare dan login ke machine tersebut, terdapat service Wazuh pada port (SIEM Platform) dan kita bisa masuk ke Wazuh Dashboard menggunakan credential pada deskripsi soal. Setelah itu, lakukan pengecekan sesuai permintaan soal

Pada soal pertama yaitu How many agents are available in the Wazuh Dashboard Server (including the default) ? What are their names? (concat with underscores). Disini saya cari di virtual machine wazuh tersebut yaitu di /var/ossec/bin/agent-control -l dan ketemu dua user yaitu silentsea dan windah

```
root@silentsea:/var/ossec/bin# ./agent_control -l

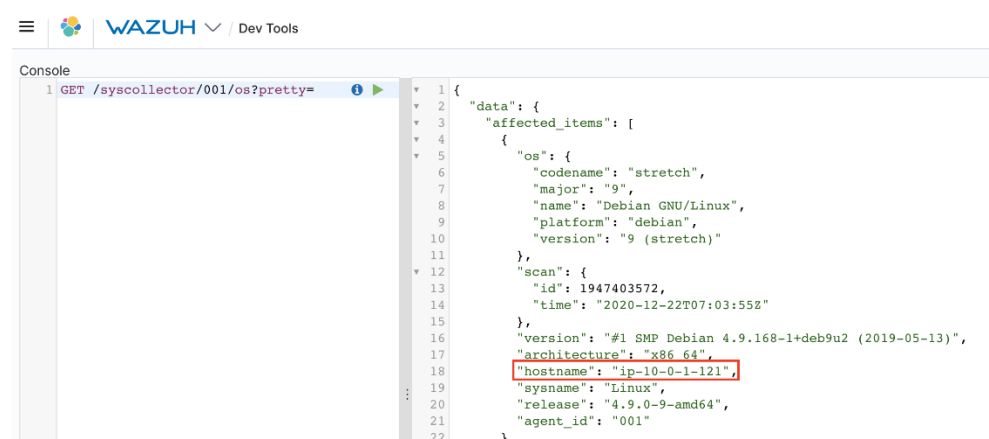
Wazuh agent_control. List of available agents:
  ID: 000, Name: silentsea (server), IP: 127.0.0.1, Active/Local
  ID: 001, Name: windah, IP: any, Disconnected

List of agentless devices:

root@silentsea:/var/ossec/bin#
```

Answer : 2_silentsea_windah

Pada soal kedua yaitu What's the hostname of the agent which has a Windows 10 Enterprise product? Disini saya cek di bagian Tools -> Console dan menuliskan agent id 001 karena agent windah merupakan windows 10 enterprise



```
1 GET /syscollector/001/os?pretty=
{
  "data": {
    "affected_items": [
      {
        "os": {
          "codename": "stretch",
          "major": "9",
          "name": "Debian GNU/Linux",
          "platform": "debian",
          "version": "9 (stretch)"
        },
        "scan": {
          "id": 1947403572,
          "time": "2020-12-22T07:03:55Z"
        },
        "version": "#1 SMP Debian 4.9.168-1+deb9u2 (2019-05-13)",
        "architecture": "x86_64",
        "hostname": "ip-10-0-1-121",
        "sysname": "Linux",
        "release": "4.9.0-9-amd64",
        "agent_id": "001"
      }
    ]
  }
}
```

Answer : DESKTOP-LCC9E2D

Pada soal ketiga yaitu, In the last 1 year, when does the Wazuh logging started for the first time? Saya cek `/var/ossec/logs/alerts/2023/Oct` dan baca file `ossec-alerts-07.json` pada bagian pertama lalu ubah time nya dari UTC ke GMT+7 sehingga menjadi berikut

Answer : 2023-10-07 19:01:33.182

Pada soal keempat, yaitu How many TOTAL events related with MITRE ATT&CK from October 7th 2023 to October 8th 2023? Saya cek pada bagian Mitre&Attack

answer : 354

Welcoming Party

Health Checking 🏠

Description:

Check out my front page : <https://lks.idcyberskills.com/>

You should see a flag!

Solution:

Flag ada di home website LKSN Cyber Security 2023 CTFd.



FLAG : LKS{Free_Flag_Buat_Kalian_Semua}